

Clase 160 — Reporte de análisis de malware

Parte: **6 — Análisis de malware** · Fuente: *Practical Malware Analysis* y guías de reporting (SANS/DFIR)

 Duración estimada: **110 min** · Nivel: **Intermedio**

Objetivo

Cerrar el ciclo: convertir todo el análisis en un **informe profesional** que distintos públicos puedan usar para decidir y actuar. El alumno aprenderá a estructurar un reporte con resumen ejecutivo, hallazgos técnicos, IOCs, TTPs, evaluación de impacto y recomendaciones, y a entregar los artefactos (YARA, IOCs, config) en formatos consumibles.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Estructurar** un informe con secciones para público ejecutivo y técnico.
2. **Redactar** un resumen ejecutivo claro, sin jerga innecesaria.
3. **Documentar** hallazgos, IOCs y TTPs de forma trazable y reproducible.
4. **Evaluar** impacto, severidad y recomendaciones accionables.
5. **Entregar** artefactos consumibles (reglas YARA, IOCs, ATT&CK layer).

Temas

#	Tema	Por qué importa
1	Audiencias del informe	Ejecutivo vs técnico vs defensor
2	Resumen ejecutivo	Decisiones sin leer lo técnico
3	Hallazgos técnicos trazables	Reproducibilidad y credibilidad
4	IOCs y TTPs estructurados	Detección y respuesta
5	Impacto, severidad y prioridad	Guía la acción
6	Recomendaciones accionables	Contención y erradicación
7	Entregables y formatos	Consumo por otros equipos

Definiciones y características

- **Resumen ejecutivo:** síntesis para dirección. Característica clave: **conclusión y riesgo** sin tecnicismos.
- **Hallazgo trazable:** afirmación respaldada por evidencia reproducible. Característica clave: **verificable**.
- **IOC estructurado:** indicador con tipo, valor y contexto. Característica clave: **listo para ingestión**.
- **Severidad:** medida de impacto y urgencia. Característica clave: **prioriza la respuesta**.

- **Entregable:** artefacto reutilizable (YARA, CSV de IOCs, capa ATT&CK). Característica clave: **acción inmediata**.

Herramientas y preparación

- Plantilla de informe (Markdown/Word) y **ATT&CK Navigator** para la capa.
- **MISP/STIX** o CSV para IOCs; repositorio de **reglas YARA**.
- Capturas de las herramientas usadas (ProcMon, Volatility, Wireshark, Ghidra) como evidencia.
- Guía de estilo: claro, conciso, sin especular más allá de la evidencia.

 **Nota ética y de seguridad:** el informe puede contener IOCs y detalles sensibles; aplica clasificación (TLP), anonimiza datos de víctimas y no incluyas la muestra ejecutable en el documento. Comparte por canales seguros.

Laboratorio guiado

Redacta el informe completo de una muestra analizada en la parte:

1. **Portada y metadatos:** nombre de la muestra, hashes (SHA-256, imphash), analista, fecha, TLP.
2. **Resumen ejecutivo (½ página):** qué es, qué hace, impacto y recomendación principal, en lenguaje llano.
3. **Detalles de la muestra:** tipo, familia, tamaño, packing, entorno de análisis (VM aislada).
4. **Análisis estático:** strings clave, imports/capacidades, entropía, hallazgos del desensamblado.
5. **Análisis dinámico:** árbol de procesos, persistencia, archivos/registro, mutex.
6. **Red y C2:** protocolo, dominios/IPs, patrón de beacon, config extraída.
7. **TTPs (ATT&CK):** tabla táctica/técnica/ID/evidencia + capa del Navigator adjunta.
8. **IOCs:** tabla estructurada (tipo, valor, contexto) y CSV/STIX adjunto.
9. **Impacto y severidad:** qué compromete, alcance y clasificación de severidad justificada.
10. **Recomendaciones:** detección (regla YARA adjunta), contención, erradicación y prevención.
11. **Anexos:** reglas YARA, config extraída, capturas de evidencia.

Ejercicios

1. Escribe un resumen ejecutivo de 8 líneas para dirección no técnica.
2. Convierte 3 hallazgos en afirmaciones trazables con su evidencia.
3. Construye una tabla de IOCs con tipo, valor y contexto.
4. Justifica una severidad (crítica/alta/media) con criterios.
5. Redacta 4 recomendaciones accionables priorizadas.
6. Adjunta una capa de ATT&CK Navigator y una regla YARA.

Reto verificable

Entrega un **informe completo** de una muestra con las 11 secciones, IOCs estructurados, capa ATT&CK, regla YARA y resumen ejecutivo, listo para su consumo por un SOC. **Criterio de aceptación:** un lector no técnico entiende el riesgo y la recomendación solo con el resumen ejecutivo, y un analista puede reproducir los hallazgos y desplegar los IOCs y la regla YARA adjuntos sin información adicional.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Resumen ejecutivo lleno de jerga	Reescríbelo para dirección: riesgo y acción
Hallazgos sin evidencia	Añade capturas/comandos que los respalden
IOCs en prosa	Estructúralos en tabla/CSV para ingestión
Recomendaciones vagas	Hazlas específicas, priorizadas y accionables
Incluir el binario en el doc	Nunca; adjunta hashes e IOCs, no la muestra

Preguntas frecuentes

 **¿Un informe para todos?** No. Estructúralo por capas: resumen para dirección, detalle para analistas, entregables para el SOC.

 **¿Cuánta especulación es aceptable?** La justa y marcada como tal. Separa hechos (con evidencia) de hipótesis (con nivel de confianza).

 **¿Qué entregables son imprescindibles?** IOCs consumibles, TTPs mapeados a ATT&CK y al menos una detección (YARA/regla EDR) reutilizable.

Referencias

- Sikorski & Honig, *Practical Malware Analysis*.
- SANS — Malware analysis reporting (posters y whitepapers). <https://www.sans.org>
- MITRE ATT&CK Navigator. <https://mitre-attack.github.io/attack-navigator/>
- FIRST — TLP. <https://www.first.org/tlp/>

Siguiendo clase

Clase 161 - Red Team vs pentest: filosofía y objetivos